

Data Protection and GDPR

Important Information

- The General Data Protection Regulation (GDPR) came into force on May 25th 2018 and is a European Law
- Data Protection Act 2018 contains the majority of the provisions from the GDPR with some additional, UK specific clauses
- DPA and GDPR are laws and all schools must be compliant
- Provides additional accountability
- A higher profile for data protection
- Enhanced rights for data subjects
- Higher expectations from everyone
- Will be unaffected by Brexit

Terminology

Personal Data

Any information relating to a person (a 'data subject') who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that person

Data Subject

The identified or identifiable living individual to whom personal data relates.

Controller

Means the natural or legal person, public authority, agency or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data; where the purposes and means of such processing are determined by Union or Member State law, the controller or the specific criteria for its nomination may be provided for by Union or Member State law

Processor

A person, public authority, agency or other body which processes personal data on behalf of the controller

Data Breach

means a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data transmitted, stored or otherwise processed

ICO

Information Commissioner's Office, the regulatory body that concerns Data Protection in the United Kingdom

Subject Access Request

The request of an individual to a data controller to exercise their right of access under the Data Protection Act (2018). The data controller must produce the requested information in an intelligible and, as far as is practicable, permanent format

Privacy Notice

A statement made to a data subject that describes how an organization collects, uses, retains and discloses personal information

Right of Erasure or Right to be Forgotten

An individual's right to have their personal data deleted by a business or other organization possessing or controlling that data.

Data Protection Officer

Under the GDPR, some organisations need to appoint a data protection officer who is responsible for informing them of and advising them about their data protection obligations and monitoring their compliance with them.

Lawful Basis for Processing

The General Data Protection Regulation requires data controllers to demonstrate one of these six legal bases for processing: consent, necessity, contract requirement, legal obligation, protection of data subject, public interest, or legitimate interest of the controller. The controller is required to provide a privacy notice, specify in the privacy notice the legal basis for the processing personal data in each instance of processing, and when relying on the legitimate interest ground must describe the legitimate interests pursued.

Consent

Any freely given specific and informed indication of wishes by means of an active step taken by the data subject which signifies their agreement to personal data relating to them being processed. Consent can be withdrawn after it has been given.

Encryption

Is a means of preventing anyone other than those who have a key from accessing data, be it in an email, on a PC or on a storage device

Accountability under GDPR

This principle ensures that controllers are more in control and in the position to demonstrate compliance with data protection principles. Accountability requires that controllers put in place internal mechanisms and control systems that demonstrates compliance and provides evidence in order to demonstrate compliance.

Many of these words and concepts are not new except for accountability and the right of erasure which comes from a Spanish case where an individual fought for the right to have his name removed by Google as the results showed information about him from a long time ago that was harmful to him now. He was successful and this right was also dubbed the right to be forgotten.

Preparing for Compliance

GDPR IS:

- Protection for Individuals
- Modern
- EU Wide
- Everyone's responsibility
- A Law
- More accountability for organisations

GDPR ISN'T:

- All about fines
- Irrelevant after Brexit
- Something that can be ignored
 - Someone else's problem

The introduction of the GDPR has raised the profile of data protection and increased awareness in all sectors and places that process personal data, especially within schools. This increased awareness may be seen by pupils and their parents and therefore you may get asked more questions about their personal data.

A Data Subject...

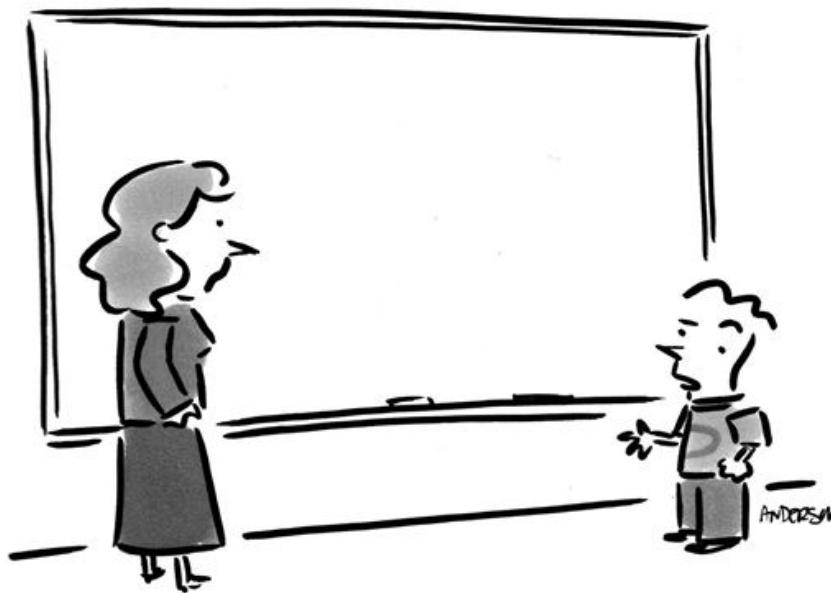
...is a natural living person

Data Subjects... It's YOUR data

Organisations... You are the custodians

Many organisations forget that the information they hold belongs to someone else and they should treat it as such.

© MARK ANDERSON, WWW.ANDERSTOONS.COM



"Before I write my name on the board, I'll need to know how you're planning to use that data."

THINK?

How would you like someone else to handle your data?

Data Breaches

A personal data breach means a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data.

A breach can be:

- Accidental or deliberate
- Committed by someone inside or outside of an organisation
- About anyone who the school holds personal data on
- Minor with little impact or severe with wide-reaching consequences

Examples of breaches

- Data shared with someone who should not have access
- Data that has been lost
- A computer being hacked
- Changing the data without permission
- Deliberating or accidentally moving the data to a location it should not be in

Severe breaches require reporting to the ICO within 72 of the organisation becoming aware which means you must follow the breach procedure as soon as you recognise a breach.

Don't use memory sticks!

A council has been fined £80,000 for losing an unencrypted memory stick storing details of 286 children with special educational needs.

An internal report by North East Lincolnshire council found the children would suffer ill-health following the loss of the memory stick, which has been missing since July 2011. The stick contained personal details, such as mental and physical health problems, home addresses and teaching requirements.

It went missing after a special educational needs teacher left it stuck in a laptop and returned to find it gone. It has never been recovered.

<https://ico.org.uk/about-the-ico/news-and-events/news-and-blogs/2017/03/council-fine-d-for-leaving-sensitive-files-in-cabinet-sent-to-second-hand-shop/>

Preparing for Compliance

The Six Data Principles

Personal data must be:

Processed lawfully

Always ensure you have an identified legal basis to process the data

For a specific purpose

You can only use data for the purpose with which you collected it. It cannot normally be used for another purpose

Kept to a minimum

Only process and keep the least amount of data you require

Accurate and up-to-date

Ensure the data is correct and relevant

Retained only for as long as it is needed

Personal data should be destroyed when it is no longer needed

Kept Securely

Always store information safely, securely and with access only for those who need it

GDPR is principle based which makes it an aspirational that means we have to demonstrate a commitment to GDPR and the principles it sets out.

Reasons to Process Data

You must have a lawful basis for processing data. There are six lawful reasons under GDPR:

1. Contractual

Such as employment contracts for staff

2. Legal Obligation

Such as collecting attendance data for statutory returns

3. Protecting Vital Interests

Such as disclosing medical information to health professionals or information for references

4. Public Interest

This applies to data collected for statutory purposes. For schools this will be most of your data

5. Legitimate Interest

Such as for marketing purposes. If schools do use email marketing, consent is the most appropriate basis for processing this data. This basis should not be used by public authorities

6. Consent

Information Society Services: For children under the age of 13, this consent must be given by their parents. Consent may also be withdrawn. No need for consent where a legal obligation exists.

Do We Need Consent?

Question: Do you need consent for every piece of personal data you hold?

No. Consent is only one of the lawful basis and many others will apply, especially when data is processed within a school. When using consent other data rights are engaged which could make it problematic. For example, the right to be forgotten can be requested when consent is used but you would likely not want to erase all the data you hold on a child in Year 2.

Question: What is the age of consent?

Whilst there is no global consent age, if you offer services to a child in the United Kingdom, 13 is the age of consent and beneath this parental consent is required. Children may also require a competency assessment to see whether they understand their rights in relation to their own personal data and if they are capable of making their own decisions.

In schools, consent will generally be only for the use of photographs on promotional activities such as the website and when sharing news with local papers and social media.

Please remember, consent must be **explicit, freely given, unambiguous...** and as easy to withdraw as it is to give.

The Rights of Data Subjects

- 1. Right to be informed**
- 2. Right of access**
- 3. Right of rectification**
- 4. Right of erasure**
- 5. Right to restrict processing**
- 6. Right to object**
- 7. Right to data portability**
- 8. Rights in relation to automated decision making**

Right of access relates to subject access requests and the data must be shared with the data subject within one month. All schools should have a SAR policy or procedure that documents how they will handle a request and what steps will be taken to fulfil the request. If a school has not received a request in the past, a rehearsal can be useful to identify any areas for improvement as they can take significant time to respond depending on the request.

Subject access requests within schools tend to be:

- From parents when their child has an issue with another child – issues over protecting the other child's information here
- From parents where they are separated from the other parent and wish to access information about them- must ensure information provided is only about the child and not the other parent
- From staff when there is a grievance

Protecting Personal Data

Reflect on the following:

What would you do if you had a data breach?

Think about the implications of a breach

- Data subject rights
- Reputation of the School and/or Trust
- Possible fines

How would you address these?

How and when do they need to be reported?

- To the ICO
- To the data subjects

How would you manage this in your school?

Do you have a procedure for this?

The key message is that actions taken to safeguard personal data indicate that an organisation takes the rights of pupils and staff seriously. The majority of breaches boil down to either human error or lack of awareness. This highlights the importance of training.

What should you be looking out for?

The same thing that the ICO looks for.

What the ICO looks for?

Things done well:

- Data protection policies
- Physical security measures
- Shredding
- Documented consent for photographs
- CCTV
- Notice of fair processing

Things that could be done better:

- Data protection training
- Processes for reporting and investigating incidents
- Process for dealing with subject access requests
- Policies for sharing data with third parties
- Data retention schedules
- USB stick / laptop / device encryption
- Email content and limiting recipients (cc'ing people)
- Not enough use of encrypted email where appropriate
- Weak passwords / not changed regularly enough
- Antivirus / firewalls / malware
- Secure printing
- Secure disposal
- Offsite data
- Bring your own device
- Secure paper storage

<https://ico.org.uk/action-weve-taken/audits-and-overview-reports/nurseries/>

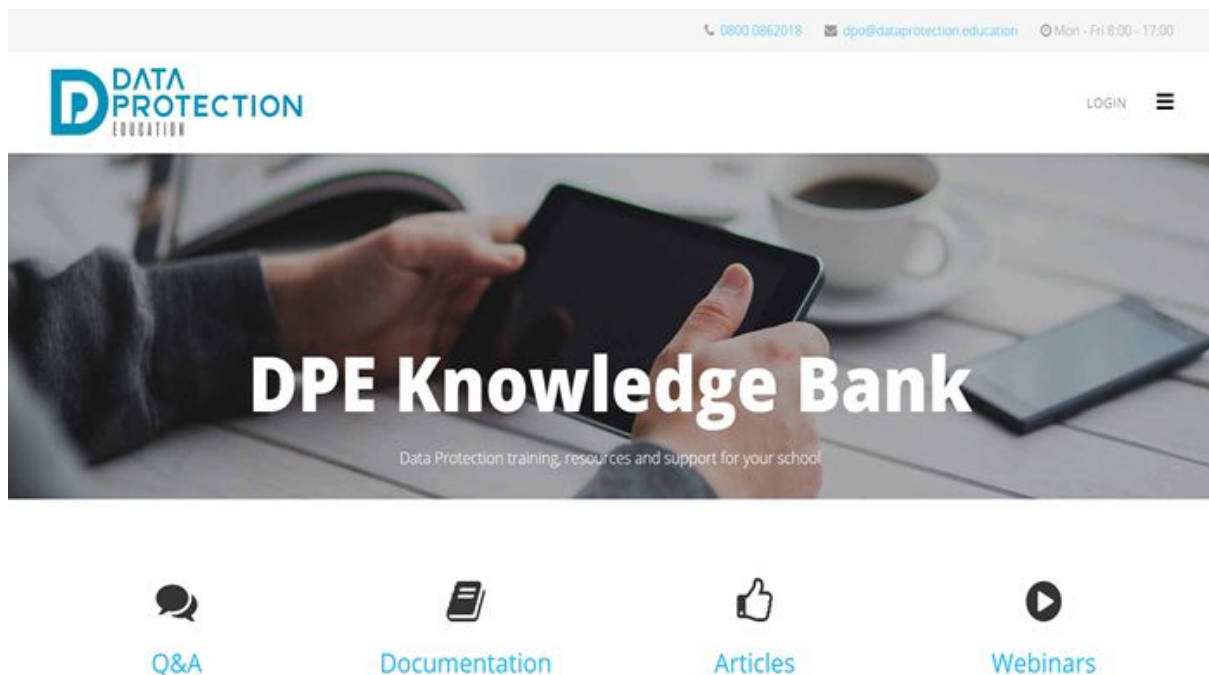
Finally

"GDPR is a Long Journey, But it is not a holiday"

(Elizabeth Denham, Information Commissioner)

Use the DPE Knowledge Bank for questions, documentation and further learning

<https://kb.dataprotection.education>



If you have any questions now or in the future, please get in touch:

info@dataprotection.education